

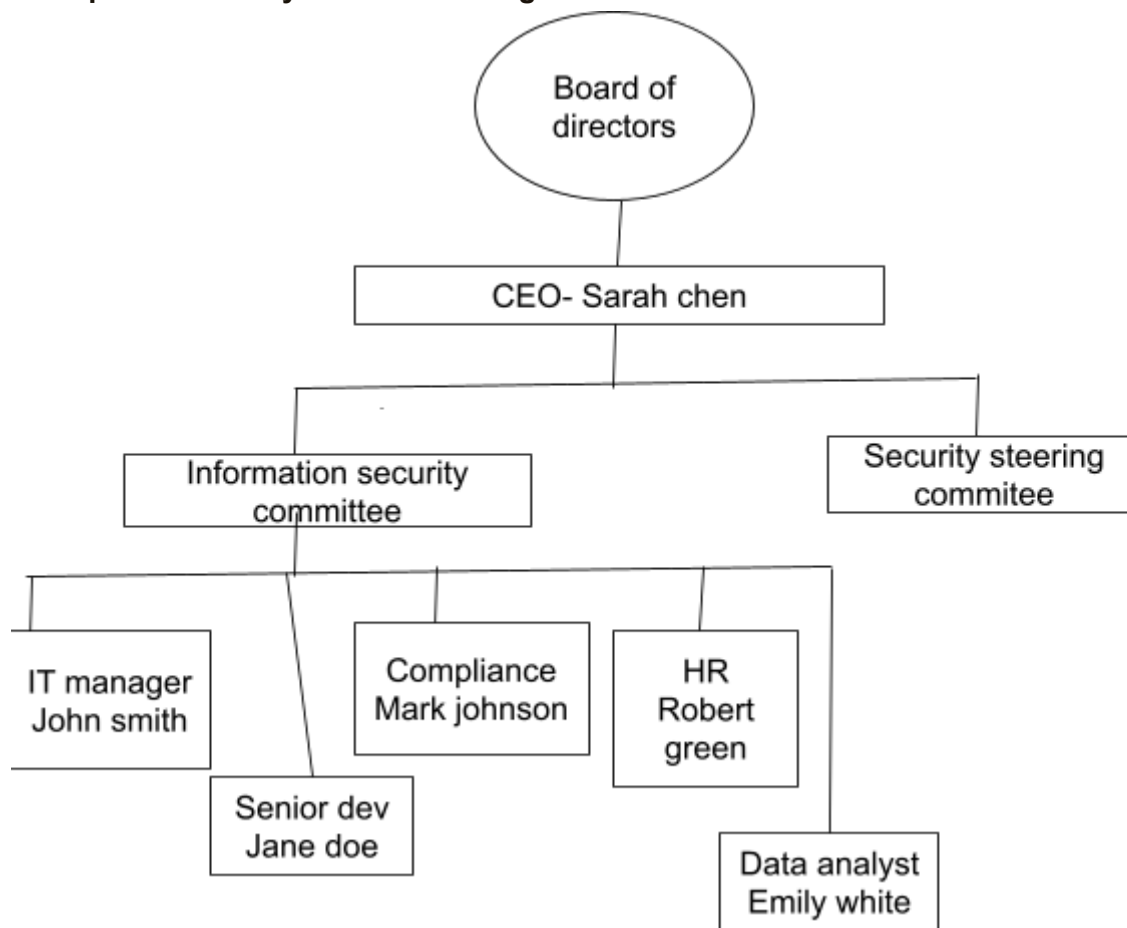
Task 1: governance gap assessment, organisational chart, RACI matrix and governance rationale.

1. Current State Governance Gap Assessment

GHC currently operates an ad-hoc security model where security responsibilities are distributed across departments without a clearly defined governance framework. While technical teams perform security related activities, there is limited executive management, inconsistent processes, and no formal structure for managing security risks across the organisation.

Governance gap	Current state weakness	Business impact
Absence of a structured security risk management.	Security activities are reactive rather than based on a formal risk assessment process.	Emerging threats may not be identified or prioritised effectively.
Lack of formal security governance authority.	Security responsibilities are unclear. IT Operations manages infrastructure and some security activities, but there is no dedicated governance authority responsible for enterprise security management.	Security decisions may lack ownership, causing delays in risk treatment and inconsistent controls.
Undefined roles and responsibilities.	GHC does not have a formal security governance hierarchy linking the Board, executive leadership, technology teams, and business functions.	Security priorities may not align with organisational objectives and growth plans.
Need for stronger collaboration between technology, business, and compliance unit.	Security decisions are mainly driven by IT teams without sufficient involvement from business, compliance, HR, and finance stakeholders.	Security controls may conflict with business needs.

2. Proposed Security Governance Organisational Structure



Board of Directors:

- Provides strategic oversight.
- Ensures security risks are appropriately managed.
- Reviews enterprise security performance and major risks.

IT Operations (John Smith)

- Implements technical security controls.
- Maintains infrastructure security.
- Supports incident response activities.

Development Team (Jane Doe)

- Integrates security into software development processes.
- Supports secure application design and vulnerability remediation.

Compliance Officer (Mark Johnson)

- Ensures security activities support healthcare regulatory obligations.
- Coordinates compliance requirements and audits.

HR Manager (Robert Green)

- Supports security through employee lifecycle processes.
- Ensures onboarding, training, and offboarding controls.

Data Analyst (Emily White)

- Supports data protection and analytics-related security requirements.
- Ensures sensitive financial information is handled securely.

3. RACI Matrix for Security Governance Activities

R = Responsible (performs the activity)

A = Accountable (owns the outcome)

C = Consulted (provides input)

I = Informed (kept updated)

Governance activity	Board	CEO	IT	Development	Compliance	HR
policy approval	I	A	C	C	C	I
Risk review	I	A	C	C	C	I
Incident response planning	I	A	R	C	C	C
Security Awareness Programme	I	A	C	I	C	R
Compliance Monitoring	I	A	C	C	R	I
Third-Party Security Risk Management	I	A	C	I	R	II

4. How the Proposed Structure Supports GHC

Accountability: The governance model creates clear ownership for security decisions. The CEO maintains executive accountability, while the information security governance team manages the security programme and ensures activities are coordinated across departments. The RACI model prevents ambiguity by clearly defining who performs activities, who approves decisions, and who must be consulted.

Transparency: The structure improves visibility by establishing formal reporting channels from operational teams to executive leadership and the Board. Security metrics, risks, incidents, and improvement initiatives can be communicated through consistent reporting mechanisms rather than informal updates.

Business Alignment: Security becomes integrated into GHC's wider business objectives rather than operating separately from business operations. The proposed governance structure supports:

- expansion into new markets,
- protection of patient information,
- secure development of new healthcare technologies,
- regulatory compliance.

Risk Management: The governance model introduces proactive security management by establishing:

- regular risk reviews
- defined security ownership
- structured incident planning
- executive oversight.

This enables GHC to identify and address risks before they become major business disruptions.

Task 2: Information Security Charter

GlobalHealth Connect Information Security Charter

1. Purpose

The purpose of this Information Security Charter is to establish the mandate, authority, and governance framework for managing information security across GlobalHealth Connect (GHC). As a healthcare technology organisation providing cloud based patient management systems, GHC depends on maintaining confidentiality, integrity, and availability of sensitive patient information while supporting business growth, innovation, and regulatory obligations. This Charter establishes security as an enterprise wide responsibility and ensures that information security activities are aligned with GHC's strategic objectives, including market expansion, operational efficiency, customer trust, innovation, and regulatory excellence.

2. Scope

This Charter applies to all GHC employees, contractors, third parties, business units, and technology environments that create, process, store, or transmit organisational information. The Information Security Programme covers:

Information Assets

- Patient health information
- Customer data
- Financial information
- Business records
- Intellectual property

Technology Systems

- Cloud based patient management platforms
- Corporate networks and infrastructure
- Applications and development environments
- Data storage platforms
- Third party technology services

People and Processes

- Employees and contractors
- Business processes involving sensitive information
- Security awareness activities
- Incident response processes

3. Authority

The Board provides strategic oversight and ensures that information security risks receive appropriate attention. The CEO is accountable for ensuring that security supports GHC’s business objectives.

The information security governance team has authority to:

- Establish and maintain security policies and standards.
- Assess and communicate information security risks.
- Require security reviews for significant business initiatives.
- Escalate unresolved security risks to executive leadership.
- Coordinate security activities across departments.
- Recommend security investments based on business risk.

Security decisions must balance business requirements, operational efficiency, innovation, and protection of organisational assets.

4. Roles and Responsibilities

Role	Responsibilities
Board of Directors	Provides strategic management, reviews major security risks, and ensures appropriate governance accountability.
Director of Information Security Governance	Leads the security governance programme, manages security strategy, coordinates risk management, and reports security posture.
Security Steering Committee	Provides cross functional management, resolves security conflicts, and ensures alignment between security and business priorities.
IT Manager (John Smith)	Implements technical security controls, manages infrastructure protection, and supports incident response activities.
Senior Developer (Jane Doe)	Supports secure software development practices and application security requirements.

Compliance Officer (Mark Johnson)	Ensures security activities support healthcare regulatory obligations and compliance requirements.
HR Manager (Robert Green)	Supports employee security processes including onboarding, training, and offboarding.
Data Analyst (Emily White)	Supports protection and appropriate handling of sensitive business and financial data.

5. Information Security Principles

5.1 Risk Based Security

GHC will prioritise security activities based on business risk and potential impact rather than applying controls without considering organisational context. Security investments and controls will focus on protecting critical systems, sensitive information, and business operations.

5.2 Business Aligned Security

Information security must support GHC's strategic objectives by enabling safe innovation, growth, and operational efficiency. Security controls should protect the organisation while allowing teams to deliver products and services effectively.

5.3 Protection of Patient Information

Protecting patient information is a fundamental responsibility of GHC. The organisation will implement appropriate measures to maintain confidentiality, integrity, and availability of healthcare data.

5.4 Clear Accountability

Information security is a shared responsibility across the organisation. Every department must understand its security responsibilities, while executive leadership maintains management of enterprise risk.

5.5 Continuous Improvement

GHC will continuously evaluate and improve its security practices through:

- risk assessments

- security monitoring
- performance measurement
- lessons learned from incidents
- maturity improvement initiatives.

5.6 Proportionate Security Controls

Security controls should match the level of risk associated with information assets and business activities. GHC will avoid unnecessary restrictions that negatively affect productivity while ensuring adequate protection.

6. Reporting Structure

Information security reporting will follow a structured governance model:

Operational Reporting

IT Operations, Development, Compliance, HR, and business functions provide security related information to the Security Governance function.

Executive Reporting

The Director of Information Security Governance provides regular security updates to:

- CEO
- Security Steering Committee
- Executive Leadership Team

Board Reporting

The Board receives periodic reports which includes:

- security risks
- incidents
- compliance status
- security performance metrics
- improvement progress.

Major security incidents must be escalated immediately through established reporting channels.

7. Review and Approval

This Information Security Charter will be reviewed annually or whenever significant organisational, technological, or regulatory changes occur.

The Charter requires approval from;

- Chief Executive Officer
- Board of Directors

Changes must follow GHC's governance change management process and must be communicated to relevant stakeholders.

CFO Justification Memo

To: Marcus Thorne, Chief Financial Officer

Subject: Justification for the GHC Information Security Charter

The Information Security Charter establishes a formal governance foundation that enables GHC to manage cybersecurity risks while supporting business growth and investment decisions. As GHC expands its market presence, integrates acquisitions, and develops innovative healthcare technologies, a structured security governance approach is necessary to protect patient information, maintain customer confidence, and ensure operational resilience.

The Charter improves accountability by clearly defining security responsibilities across leadership, technology teams, compliance functions, and business units. This allows security investments to be prioritised based on measurable business risks rather than reactive responses to incidents. Furthermore, the Charter supports GHC's strategic goals by enabling secure expansion into new markets, improving operational efficiency through structured processes, supporting AI driven innovation through appropriate security management, and strengthening regulatory readiness. From a financial perspective, the Charter provides a framework for making informed security investment decisions. By improving risk visibility, reducing the likelihood of major security incidents, and establishing clear governance processes, GHC can better balance security spending with business priorities while protecting long term organisational value.

Task 3: Board Reporting and Security Metrics

1. Board Executive Summary

Overall Security Posture:  RED

GHC’s current security posture indicates increasing exposure due to a consistent rise in security threats, declining vulnerability remediation performance, and increasing high risk incidents over the six month reporting period. While security awareness training participation has improved from 45% to 70%, this positive progress has not yet resulted into reduced security events. Phishing attempts increased from 150 incidents in September to 320 incidents in February, while high risk incidents increased from 2 to 7 during the same period.

The most significant concern is the decline in vulnerability patching performance. Critical vulnerability remediation reduced from 67% in September to 55% in February, increasing the likelihood that known weaknesses remain exposed. GHC should prioritise improvements in vulnerability management, incident prevention, employee security awareness, and executive oversight to reduce operational and reputational risks.

2. Selected Board Security Metrics

Metric	Current status	Six month trend	Business commentary
High Risk Security Incidents	7 incidents (February)	Increased from 2 incidents in September to 7 incidents in February	The rising number of serious incidents indicates increasing exposure and potential impact on customer trust, operational continuity, and regulatory obligations.
Phishing Attempts	320 attempts (February)	Increased consistently from 150 in September to 320 in February	Phishing remains a significant threat to GHC because successful attacks could compromise patient information and business

			systems.
Critical Vulnerability Patching Rate	55% patched (February)	Declined from 67% in September to 55% in February	Reduced patching effectiveness increases the likelihood of exploitation of known vulnerabilities within critical systems.
Security Awareness Training Completion	70% completion (February)	Improved from 45% in September to 70% in February	Improvement demonstrates stronger employee engagement, however, completion remains below the level required for effective organisation wide risk reduction.
Malware Events	50 events (February)	Increased from 25 events in September to 50 in February	Growing malware activity indicates increased threat exposure and requires stronger preventive and detection capabilities.

3. Priority Risk and recommendation

Risk	Recommendation
High risk incidents increased from 2 incidents in September to 7 incidents in February. Potential Impact include: • Exposure of sensitive patient information. • Regulatory penalties. • Loss of customer confidence. • Operational disruption.	Establish a formal incident reduction programme involving: • improved threat monitoring, • incident response testing, • Root cause analysis, • executive review of major incidents.

Critical vulnerability patching decreased from 67% to 55%.

Potential Impact:

- Increased likelihood of cyber exploitation.
- Higher business interruption risk.
- Increased compliance concerns.

Implement a vulnerability management improvement plan which:

- defined patching timelines
- vulnerability prioritisation based on risk
- regular reporting to executive leadership.

4. Metric Selection Rationale

The selected metrics above provide the Board with a balanced view of GHC's security posture by covering:

1. Threat Exposure: Phishing attempts, Malware events

These metrics demonstrate the level of external attack activity affecting the organisation.

2. Control Effectiveness: Critical vulnerability patching rate

This shows whether GHC's security controls are reducing exposure.

3. Human Risk Management: Security awareness training completion

Employees represent a critical part of GHC's security defence, particularly against social engineering attacks.

4. Business Impact: High risk security incidents

This provides leadership with visibility into events that could affect reputation, operations, compliance, and customer trust.

Together, these metrics allow the Board to understand current risks, evaluate security performance, and make informed investment decisions.

Task 4 : Security Steering Committee

1. Security Steering Committee Terms of Reference

1.1 Purpose

The purpose of the Security Steering Committee (SSC) is to provide strategic direction, management, and decision making support for GHC's information security programme. The SSC ensures that security initiatives align with business objectives while maintaining appropriate protection of patient information, organisational assets, and technology environments. The committee provides a platform for resolving cross functional security issues, prioritising security investments, reviewing risks, and improving organisational security maturity.

1.2 Scope

The SSC will oversee and provide guidance on:

- Information security strategy and roadmap.
- Security policies, standards, and procedures.
- Enterprise security risks and risk treatment plans.
- Major security incidents and lessons learned.
- Security investments and resource allocation.
- Regulatory and compliance requirements.
- Security awareness and training initiatives.
- Security considerations for new technologies and business projects.

The SSC will not replace operational security responsibilities. Instead, it provides governance, management, and strategic direction.

1.3 Membership

Member	Role
CEO- Sarah chen	Executive sponsor and final escalation authority
Marcus Thorne - CFO	Provides financial management and investment considerations
Elena Rodriguez -CTO	Represents technology strategy and innovation requirements
John Smith - IT Manager	Represents infrastructure and operational security requirements
Jane Doe -Senior Developer	Represents application development and

	secure software practices
Mark Johnson -Compliance Officer	Ensures regulatory and compliance alignment
Robert Green -HR Manager	Represents employee security and awareness requirements
Emily White -Data Analyst	Provides data protection and business information perspective

1.4 Responsibilities

The SSC are incharge:

1. Security Governance management
 - Review security strategy and ensure alignment with organisational goals.
 - Monitor progress of security improvement initiatives.
2. Risk Management
 - Review significant security risks.
 - Approve risk treatment priorities.
 - Ensure appropriate ownership of security risks.
3. Policy Review and Approval Support
 - Review security policies before executive approval.
 - Ensure policies balance security requirements and business usability.
4. Incident Management
 - Review major security incidents.
 - Evaluate lessons learned.
 - Recommend improvements to prevent recurrence.
5. Security Investment Decisions
 - Review security related funding requests.
 - Ensure investments provide appropriate risk reduction.
6. Conflict Resolution
 - Resolve disagreements between departments regarding security controls.
 - Ensure decisions consider security, operational efficiency, and business requirements.

1.5 Meeting Cadence

The SSC will operate under the following schedule:

Meeting type	Frequency
Regular SSC Meeting	Monthly
Risk and Compliance Review	Quarterly
Major Incident Review	Within 5 business days after significant

	incidents
Annual Strategy Review	Annually

1.6 Decision Authority

The SSC has authority to:

- Recommend security policies and standards.
- Prioritise security initiatives.
- Approve security risk treatment recommendations within delegated authority.
- Escalate unresolved security issues to executive leadership.
- Make recommendations regarding security investments.

Final accountability remains with executive management and the Board. The CEO retains final decision authority for major business security conflicts.

1.7 Reporting Structure

The SSC reports to the CEO and Executive Leadership Team. Provides updates to the Board of Directors

Reports will include:

- Security risk status.
- Major incidents.
- Security programme progress.
- Compliance concerns.
- Security performance metrics.
- Required decisions or approvals.

2. First Security Steering Committee Meeting Agenda

Meeting Title:

GHC Security Steering Committee Initial Meeting

Date:

To be scheduled

Chair:

Director of Information Security Governance

Agenda

1. Opening and Introductions
2. Review of GHC Security Governance Objectives
3. Current Security Risk Overview
4. Password Policy Conflict Discussion
5. Password Policy Decision
6. Security Metrics Review
7. Security Roadmap Priorities
8. Actions and Owners
9. Closing Remarks

3. CEO Briefing Note

To: Sarah Chen, Chief Executive Officer

Subject: Establishment of the Security Steering Committee

The creation of the Security Steering Committee provides GHC with a formal mechanism for managing information security decisions across business and technology functions. The recent disagreement between the CTO and IT Manager regarding password policy demonstrates the need for a structured process where competing priorities can be evaluated using business risk and security principles. The SSC ensures that security decisions are not made solely from a technical perspective but consider organisational objectives, operational impact, regulatory responsibilities, and user experience. By bringing together leadership from technology, compliance, finance, HR, and security governance, the committee creates shared ownership of information security.

The committee will also improve GHC's ability to manage risk proactively by reviewing security performance, prioritising investments, and ensuring security initiatives support business growth. This approach allows GHC to maintain customer trust, protect sensitive patient information, and continue innovation while maintaining appropriate security controls.

Task 5 : Governance Maturity Assessment

1. Current Governance Maturity Assessment

Domain	Maturity level	Assessment
Policy & Documentation	Level 2-Initial	GHC has security policies inherited from acquisitions, but they are inconsistent, outdated, and not always aligned with current business needs.
Risk Management	Level 1- Ad Hoc	Security risk management is reactive, with limited evidence of structured risk assessments or proactive risk treatment planning.
Roles & Responsibilities	Level 1 -Ad Hoc	Security ownership is unclear. IT Operations performs some security activities, but there is no clearly defined governance authority responsible for enterprise security accountability.
Metrics & Reporting	Level 2 - Initial	Technical security metrics exist, but they are not consistently converted into business focused reporting suitable for executives and Board decision making.
Training & Awareness	Level 2 - Initial	Mandatory annual training exists, but employee engagement remains low and there is limited evidence of continuous security awareness activities.
Compliance	Level 2 - Initial	Compliance activities are mainly audit driven rather than continuously monitored, increasing the possibility of gaps between audits.

2. 12–18 Month Governance Improvement Roadmap

Initiative	Objective	Key activities	Measurable outcome
Establish Formal Security Governance Framework	Create clear ownership and accountability for security decisions.	- Establish a Security Governance function. - Launch Security Steering Committee. - Define security roles using the RACI model. - Approve Information Security Charter	Security responsibilities formally assigned across GHC with executive management established.
Implement Formal Risk Management Process	Move from reactive security management to proactive risk based decision making.	- Build a security risk register. - Conduct regular risk assessments. - Define risk acceptance and escalation procedures.	Security risks identified, prioritised, assigned owners, and tracked regularly.
Improve Security Metrics and Reporting	Provide executives and the Board with meaningful security visibility.	- Define Board level security metrics. - Create regular security dashboards. - Link technical metrics to business impact.	Consistent executive reporting that supports informed security investment decisions.
Strengthen Security Culture and Compliance Monitoring	Improve employee security behaviour and regulatory readiness.	- Introduce continuous awareness campaigns. - Conduct phishing simulations. - Establish compliance monitoring activities.	Increased employee engagement and improved compliance readiness

3. Board Executive Summary

Current Governance Position

GHC's current security governance maturity is assessed as Level 2-Initial, with several areas operating at Level 1 due to unclear ownership and reactive processes. While the organisation has implemented some security activities, rapid growth, acquisitions, and increasing security threats have created the need for a more structured governance approach.

The main challenges include inconsistent policies, unclear accountability, limited proactive risk management, and insufficient translation of technical security information into business focused reporting.

Strategic Importance of the Roadmap

The proposed 12–18 month roadmap will move GHC toward a Level 3 -Defined security governance capability, where security processes are documented, standardised, and supported by clear responsibilities.

Improving governance maturity will enable GHC to:

- protect sensitive patient information more effectively;
- maintain customer trust;
- support secure expansion into new markets;
- improve regulatory readiness;
- make better informed security investment decisions;
- enable innovation through controlled and secure technology adoption.

By establishing formal governance structures, improving risk management, and strengthening security culture, GHC can transition from a reactive security model into a proactive, business aligned security programme.